



00 Ringkasan Eksekutif

- 01 Arsitektur Sistem
- 02 Tumpukan Teknologi
- 03 Model & Skema Data
- 04 Peta API Backend
- 05 Arsitektur Frontend
- 06 Modul Fungsional
- 07 Keamanan & Akses
- 08 Payment & Integrasi
- 09 Deployment & Operasional
- 10 Risiko & Utang Teknis
- 11 Roadmap Rekomendasi

— SYSTEM BLUEPRINT · KMSIT COMPUTER

Cetak biru arsitektur platform KMSIT Computer

Dokumen referensi teknis menyeluruh: arsitektur, skema database, API, struktur frontend, keamanan, integrasi pembayaran, hingga risiko dan roadmap — disusun dari audit langsung terhadap kode sumber backend dan frontend.

Disusun 08 Sep 2026

Peran IT Analyst · Architect · PM

Repo c:\ServBay\www\kms

Model Monolith · single deploy

```
$ kmsit blueprint --scan backend/ frontend/ --deep
✓ 42 tabel domain · 90+ endpoint API · 48 route SPA dipetakan
$ kmsit blueprint --assess arsitektur monolith Laravel + React
✓ status: produksi-siap dengan 6 catatan utang teknis (lihat §10)
```

00 Ringkasan Eksekutif

KMSIT Computer adalah platform tiga-dalam-satu: **Learning Management System** (kelas, kurikulum, kuis, sertifikat ber-QR), **e-commerce** (produk fisik & digital, keranjang, voucher, tiga payment gateway), dan **CMS** (artikel, berita, tutorial, aktivitas, halaman statis, homepage builder, menu). Seluruh sistem berjalan sebagai **satu aplikasi Laravel 13** yang menyajikan API REST sekaligus meng-host build production dari SPA React – bukan dua layanan terpisah.

42

TABEL DOMAIN

33

CONTROLLER API

48

ROUTE SPA

3

PAYMENT GATEWAY

29

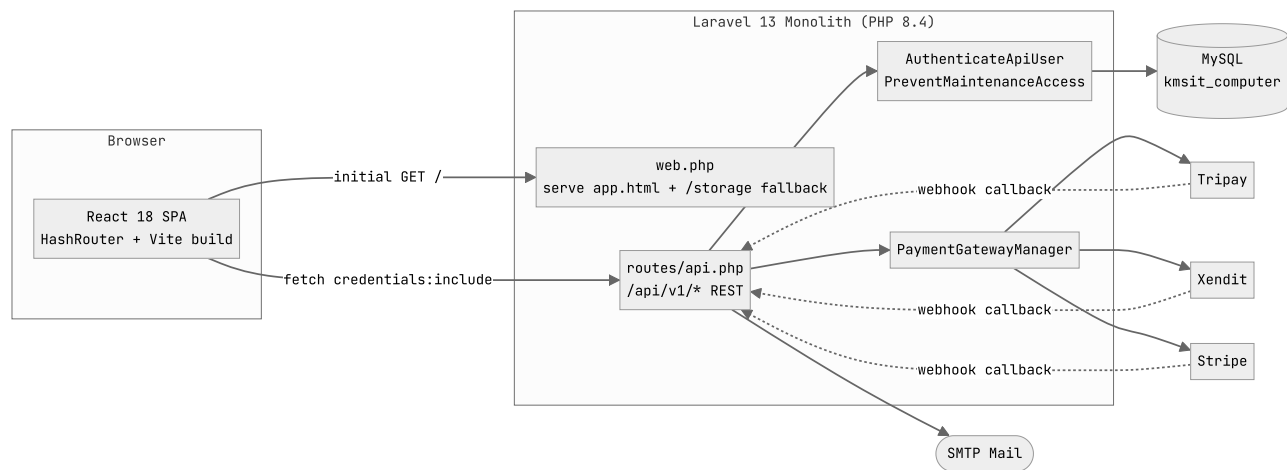
TEST BACKEND

Karakter arsitektur yang paling menentukan: **ID non-auto-increment 12 karakter** di hampir semua tabel utama (bukan bigint biasa), **otentikasi berbasis session-cookie** (bukan token bearer meski paket Sanctum ter-install), **RBAC berbasis kolom permissions JSON per-role** yang dicek manual di tiap controller, dan **installer wizard bawaan (/install)** yang menulis .env dan menjalankan migrasi tanpa akses SSH – dirancang agar bisa naik ke shared hosting oleh non-developer.

- ✓ Selama sesi audit ini, lima bug produksi nyata ditemukan & diperbaiki langsung di kode: validasi partial-update yang menghapus data (avatar hilang saat simpan profil, produk gagal publish), allowlist settings/public yang tidak lengkap (footer tidak menarik data dashboard), serta mismatch kolom pada CMS content (500 error saat membuat berita/tutorial). Semua tercakup regression test baru.

01 Arsitektur Sistem

Model deploy monolitik: satu proses PHP-FPM melayani API dan SPA shell dari direktori publik yang sama.



Tidak ada proxy dev terpisah untuk `/api` di `vite.config.js` — di produksi, build frontend disatukan ke backend/public lewat postbuild hook (lihat §09).

Alur permintaan halaman

1. GET `/` dan seluruh path non-API ditangkap catch-all di `web.php` → menyajikan `public/app.html` (shell SPA hasil build Vite).
2. React Router (HashRouter) mengambil alih routing di sisi klien menggunakan fragment `#/...`
3. AppProvider memanggil GET `/api/v1/auth/me`, GET `/api/v1/settings/public`, dan GET `/api/v1/categories` saat mount untuk hidrasi state global.
4. Setiap permintaan API terautentikasi melalui cookie session Laravel (bukan header Authorization), diperkuat token CSRF dari endpoint Sanctum `/sanctum/csrf-cookie`.

02 Tumpukan Teknologi

Backend

Laravel **13.17** · PHP **8.4** · MySQL · Sanctum **4.3** (session-cookie, bukan bearer-token aktif) · PHPUnit **12.5** · Laravel Pint

Frontend

React **18.2** · TypeScript **5.7** (strict) · Vite **6.3** · Tailwind **4.1** (CSS-first @theme, tanpa `tailwind.config.js`) · React Router **6.8**

Editor & UI kit

Tiptap (rich text CMS) · @dnd-kit (drag-drop homepage builder & kurikulum) · recharts + SVG chart custom · react-qr-code (sertifikat) · canvas-confetti

Tipografi produk

Display Space · Grotesk · Body Manrope · Mono JetBrains Mono — identitas yang sama dipakai ulang pada dokumen ini.

Pembayaran

Tripay · Xendit · Stripe — diimplementasi manual via Http facade (tanpa SDK resmi), di belakang PaymentGateway contract.

Build & deploy

Satu pipeline composer setup: install → migrate --force → npm run build → sinkron otomatis ke backend/public.

03 Model & Skema Data

42 tabel domain (di luar tabel bawaan Laravel: cache, jobs, sessions, personal_access_tokens). Hampir semua primary key adalah string 12-karakter non-auto-increment; pengecualian: audit_logs (bigint) dan settings (PK = setting_key).

Identitas & Akses

roles · permissions · users · password_reset_tokens · sessions

TABEL	FUNGSI	KOLOM / RELASI KUNCI
roles	Definisi peran & hak akses	role_key (unik) · name · p
users	Akun semua peran (student/instructor/admin/super_admin)	role_key→roles · email (u
password_reset_tokens	Token reset password	email PK · token · createc
sessions	Session store (driver database)	user_id · ip_address · pay
personal_access_tokens	Tabel Sanctum (terpasang, tidak aktif dipakai sebagai guard — lihat §07)	tokenable morph · abilitie

Pembelajaran (LMS)

categories • courses • course_sections • lessons • enrollments • lesson_progress

TABEL	FUNGSI	KOLOM / RELASI KUNCI
categories	Kategori lintas-scope (course/article/news/tutorial/product)	scope enum • slug (unik per scope)
courses	Kelas: harga, status moderasi, kurikulum	instructor_id→users • category_id
course_sections	Bagian kurikulum per kelas, berurut	course_id→courses cascade • sort
lessons	Materi per bagian: 8 tipe konten	type:text youtube video pdf file im
enrollments	Pendaftaran siswa ke kelas + progres	unique(user_id,course_id) • progres
lesson_progress	Checklist penyelesaian materi per siswa	unique(user_id,lesson_id)

Penilaian (Kuis)

quizzes • quiz_questions • quiz_options • quiz_attempts

Commerce Inti

orders • order_items • payments • webhook_logs

Toko & Voucher

products • product_variants • vouchers • cart_items

Fulfillment & Finansial Instruktur

digital_deliveries • instructor_wallet_transactions • withdrawals

Konten CMS

articles • news • tutorials • activities • pages • homepage_blocks

Struktur Situs & Media

menus • menu_items • settings • media

Sertifikasi & Sistem

certificate_templates • certificates • notifications • audit_logs • contact_messages

Semua route berprefiks `/api/v1`. Autentikasi ditegakkan oleh middleware kustom `AuthenticateApiUser` (bukan middleware bawaan Sanctum), dipasang per-grup route – bukan lewat Policy/Gate terpusat.

Auth & Profil 9 endpoint ▾

	PATH	CONTROLLER	CATATAN
POST	/auth/register	AuthController@register	throttle 6/menit
POST	/auth/login	AuthController@login	throttle 6/menit
GET	/auth/me	AuthController@me	guard web
POST	/auth/logout	AuthController@logout	
POST	/auth/forgot-password	PasswordResetController@request	throttle 5/menit, kirim email
POST	/auth/reset-password	PasswordResetController@reset	throttle 5/menit
PUT	/profile	ProfileController@update	hanya menulis avatar bila field dikirim
POST	/profile/avatar	ProfileController@avatar	throttle 20/menit, semua role
PUT	/profile/password	ProfileController@password	

Kelas, Kurikulum & Kuis 18 endpoint ▶

Sertifikat 8 endpoint ▶

Order, Pembayaran & Webhook 9 endpoint ▶

Toko, Keranjang & Wallet 15 endpoint ▶

CMS, Homepage, Menu, Media & Settings ≈22 endpoint ▶

Admin, Notifikasi, Search & Install ≈15 endpoint ▶

05 Arsitektur Frontend

SPA React dengan HashRouter, state global via Context, dan lapisan API tipis (`lib/api.ts`) di atas `fetch`.

Pola struktural

State

`state/store.tsx` — satu `AppProvider` berisi user, tema (`light/dark/system`), bahasa (`id/en`), toast queue. Sesi login sepenuhnya server-driven lewat cookie, **bukan** `localStorage`.

Lapisan API

`lib/api.ts` — >90 fungsi bertipe, dikelompokkan per domain (`auth`, `courses`, `quizzes`, `shop`, `wallet`, `cms`, `settings`, `admin`). Setiap mutasi state-changing memakai CSRF cookie Sanctum.

Komponen inti

`Shell.tsx` (`header/sidebar/footer publik & dashboard`), `ui.tsx` (design-system: `Modal`, `DataTable`, `BarChart SVG custom`, `dsb.`), `icons.tsx` (± 80 ikon SVG buatan sendiri + palet warna `iconTone`).

Theming

`lib/theme.ts` — sistem `SurfaceTheme/BlockTokens` per blok (`header`, `card`, `sidebar`, `dst`), disimpan sebagai JSON di `settings.theme_website / theme_dashboard`, di-inject sebagai CSS var oleh `ThemeVarsInjector`.

Peta rute SPA (48 route)

Halaman publik 21 rute

PATH	KOMPONEN	AKSES
/	HomePage	publik
/courses , /courses/:slug	CoursesCatalog, CourseDetailPage	publik

PATH	KOMPONEN	AKSES
/learn/:slug	LearnPage	butuh enrollment
/checkout/:orderId	CheckoutPage	butuh order milik
/articles, /news, /tutorials, /activities (+ :slug)	*Page / *Detail (per tipe)	publik
/page/:slug	PageView	publik, CMS stat
/about, /contact, /shop	AboutPage, ContactPage, ShopPage	publik
/certificate/verify[/:number]	VerifyPage	publik
/login, /register, /forgot	LoginPage, RegisterPage, ForgotPage	publik
/install	Installer	publik (wizard -

Dashboard — semua peran 27 rute, digerbangi perm ▶

06 Modul Fungsional

Learning Management

Kelas → bagian → materi (8 tipe: teks, video, YouTube, PDF, file, gambar, URL, embed). Progres per-materi, kelulusan berbasis kuis, moderasi kelas instructor (draft→pending→published/rejected).

Assessment Engine

4 tipe soal (single/multiple/boolean/short), penilaian di server (QuizController@submit), batas percobaan & waktu, opsi acak.

Sertifikasi

Terbit otomatis usai kelas selesai, nomor unik + QR, verifikasi publik tanpa login, template visual (3 tema × 2 frame) dikelola admin.

Commerce & Checkout

Order kelas/produk terpisah, 3 gateway pembayaran, kalkulasi fee & voucher server-side, webhook idempotent via `payload_hash`.

Toko & Digital Delivery

Produk fisik (stok, alamat kirim) & digital (license key + link unduh pasca-bayar), varian produk, keranjang multi-user.

Wallet Instruktur

Ledger earning per-order dengan potongan platform otomatis, alur permintaan → approve/reject pencairan oleh admin.

CMS Konten

5 tipe konten (artikel/berita/tutorial/aktivitas/halaman) dengan editor Tiptap WYSIWYG, SEO fields, status draft/published, soft-delete.

Homepage & Menu Builder

Blok homepage drag-and-drop (@dnd-kit), menu header/footer bertingkat, editor tema visual per-blok (warna/opacity) untuk website & dashboard terpisah.

Admin & RBAC

4 peran (super_admin/admin/instructor/student), permission array per-role di kolom JSON, approval instructor manual, audit log setiap aksi sensitif.

Notifikasi & Pesan

Notifikasi in-app per user (bukan lewat sistem Notification Laravel — tulis langsung ke tabel), inbox pesan form kontak publik.

Pengaturan Situs

Settings umum, integrasi (YouTube/Zoom/GMeet), bahasa, mode maintenance, backup export, viewer audit log.

Installer Wizard

Alur /install tanpa SSH: cek requirement → test koneksi DB → tulis .env → migrate+seed → buat akun admin pertama.

07 Keamanan & Model Akses

Autentikasi

Login memakai **session-cookie Laravel standar** (guard web), diperkuat CSRF via endpoint `/sanctum/csrf-cookie` yang men-set cookie XSRF-TOKEN — frontend menempelkannya sebagai header X-XSRF-TOKEN pada tiap mutasi. Middleware kustom `AuthenticateApiUser` mencoba guard `sanctum` lalu web; karena `config/auth.php` hanya mendefinisikan guard web, jalur token bearer Sanctum (`personal_access_tokens`, trait `HasApiTokens`) **tidak benar-benar aktif** — lihat §10.

Otorisasi (RBAC)

4 peran dengan daftar permission tersimpan sebagai JSON di `roles.permissions`. Pemeriksaan akses dilakukan **inline per-controller** (mis. `abort_unless(in_array($user->role_key, [ ... ]))`) — bukan lewat Laravel Policy/Gate terpusat. Di frontend, gate serupa direplikasi lewat komponen Guard + fungsi `can(user, perm)`.

Rate limiting kunci

ENDPOINT	LIMIT
auth/login, auth/register	6 / menit
auth/forgot-password, reset-password	5 / menit
install/install	3 / menit
install/configure, contact	5 / menit
quiz-attempts/submit, orders/{id}/payment, wallet/withdrawals, install/test-db	10 / menit
profile/avatar	20 / menit
quizzes/{id}/attempts, voucher/validate, media upload	30 / menit
search, cart add, lesson/complete	60 / menit

payments/webhook/{gateway}

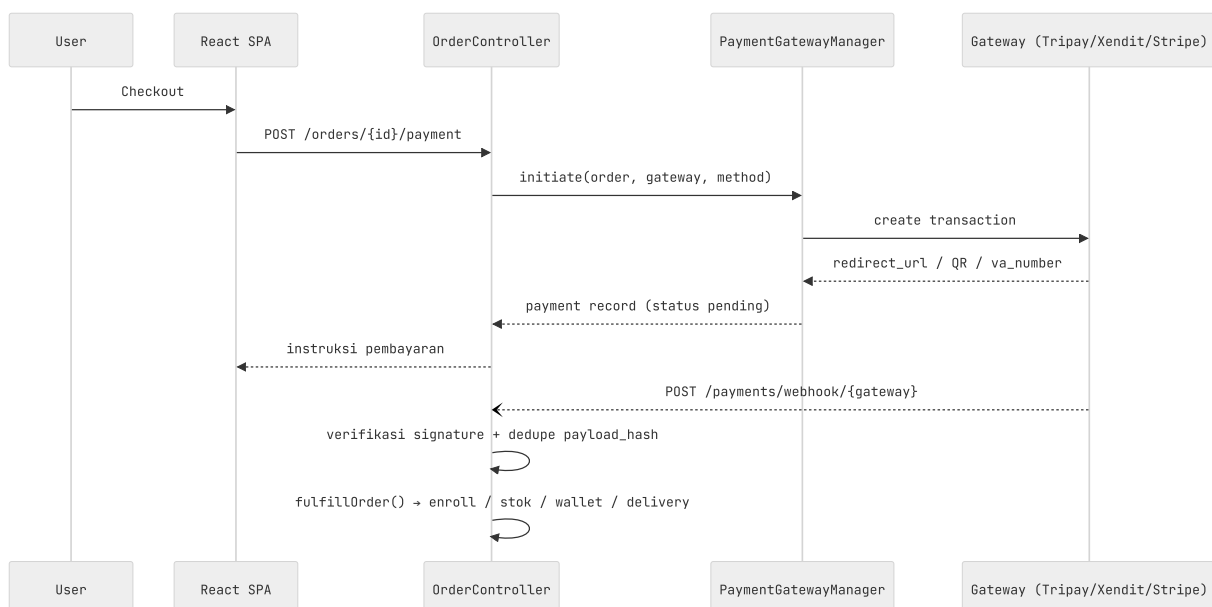
120 / menit

Pertahanan lain

- **Maintenance mode** (PreventMaintenanceAccess, global middleware): mengunci seluruh situs kecuali admin/super_admin dan endpoint auth+settings publik; *fail-open* jika tabel settings belum tersedia (fresh install) agar tidak mengunci diri sendiri.
- **Path sensitif diblok 404** secara eksplisit di web.php: /.env, /composer.json, /package.json, /database/*, /backend/*.
- **Kredensial gateway pembayaran** (private/secret key) diblok dari endpoint PUT /settings* – hanya bisa diubah lewat environment server, tidak lewat API meski oleh admin.
- **Fallback penyajian file** /storage/{path} lewat MediaController@serve untuk hosting yang tidak mendukung symlink().

08 Payment & Integrasi

Tiga gateway (**Tripay**, **Xendit**, **Stripe**) diimplementasikan manual di belakang contract `App\Contracts\PaymentGateway`, dipilih runtime oleh `PaymentGatewayManager` – tanpa SDK pihak ketiga, murni lewat `Http facade` Laravel.



Admin memilih gateway aktif & mode (sandbox/live) lewat **Settings** → **Pembayaran**, disimpan di tabel **settings** (**gateway_active**, **gateway_mode**) — kredensial rahasianya tetap dari **.env** / **config/payment.php**, tidak pernah tersimpan di database maupun bisa diubah lewat API biasa.

09 Deployment & Operasional

Pipeline build → deploy

1. `npm run build` (Vite) menghasilkan **frontend/dist/**.
2. Hook **postbuild** menjalankan **scripts/sync-backend-assets.mjs**: menghapus **backend/public/assets** lama, menyalin bundle baru, dan menulis ulang **dist/index.html** → **backend/public/app.html**.
3. **Laravel** (**web.php**) menyajikan **app.html** untuk **/** dan seluruh path non-API/non-storage sebagai fallback SPA.
4. Script **composer setup** merangkai seluruh proses instalasi server: **install dependency** → **.env** → **key:generate** → **migrate --force** → **build frontend**.

Zero-config bootstrap

bootstrap/app.php otomatis membuat **.env** dari **.env.production.example** dengan **APP_KEY** acak jika belum ada saat boot pertama — memungkinkan wizard **/install** berjalan di shared hosting tanpa akses shell.

Pre-flight check

`php artisan production:check` memverifikasi: **APP_ENV=production**, **APP_DEBUG=false**, **APP_KEY** ter-set, **APP_URL HTTPS**, konektivitas **MySQL**, symlink **public/storage**, mode payment gateway valid — serta memperingatkan (non-fatal) bila **QUEUE_CONNECTION=sync**.

10 Risiko & Utang Teknis

Ditemukan langsung dari audit kode — bukan asumsi. Diurutkan berdasarkan dampak.

Guard Sanctum tidak benar-benar aktif

KEAMANAN / ARSITEKTUR

config/sanctum.php tidak ada dan **config/auth.php** cuma mendefinisikan guard web — trait **HasApiTokens** dan tabel **personal_access_tokens** terpasang tapi jalur token bearer tidak benar-benar bisa dipakai untuk auth API eksternal (mobile app / integrasi pihak ketiga di masa depan akan gagal diam-diam).

Kode legacy client-side menduplikasi logika bisnis

MAINTAINABILITY

`lib/lms.ts` & `lib/commerce.ts` berisi ulang logika scoring kuis, kalkulasi fee wallet, dan validasi voucher yang *juga* ada di backend — kini hanya dipakai jalur seed installer, tapi berisiko membingungkan developer baru yang mengira ini sumber kebenaran runtime.

Mail & job berjalan sinkron secara default

RELIABILITY

`QUEUE_CONNECTION=sync` membuat `PasswordResetMail` (meski `ShouldQueue`) terkirim inline dalam request — request lambat menunggu SMTP, dan gagal total jika proses PHP mati di tengah kirim.

Bundle JS tunggal ±1 MB tanpa code-splitting

PERFORMA

Seluruh kode dashboard admin ikut terkirim ke pengunjung publik yang hanya membuka homepage — belum ada `dynamic import()` per-route.

Cakupan test frontend nol

KUALITAS

Backend punya 29 test PHPUnit; frontend tidak punya test runner sama sekali — logika kritikal (kalkulasi keranjang, scoring kuis di UI, alur checkout) tidak diverifikasi otomatis.

Pemeriksaan RBAC tersebar, bukan terpusat

MAINTAINABILITY

Setiap controller memeriksa `role_key/permission` secara manual — mudah lupa menambahkan guard saat endpoint baru dibuat; belum ada Policy/Gate Laravel sebagai satu sumber kebenaran.

Dependency tak terpakai

HOUSEKEEPING

`lucide-react` (ikon dibuat manual di `icons.tsx`) dan `@supabase/supabase-js` tercantum di `package.json` tapi tidak dirujuk kode manapun.

11 Roadmap Rekomendasi

P0 Tentukan sikap terhadap Sanctum token auth

Konfigurasi `config/sanctum.php` + guard `api` dengan benar bila token bearer akan dipakai (mis. app mobile ke depan), atau lepas trait/tabel yang tidak dipakai untuk mengecilkan permukaan serangan.

P0 Pasang worker queue produksi

Jalankan `QUEUE_CONNECTION=database + php artisan queue:work` (via Supervisor) agar email & job berat tidak memblokir request.

P1

Sentralisasi RBAC lewat Policy/Gate

Migrasikan pengecekan `role_key` inline ke Laravel Policies agar aturan akses satu sumber kebenaran dan mudah diaudit.

P1

Code-split bundle dashboard vs publik

Pisahkan chunk admin dari chunk publik lewat `React.Lazy` per-route agar pengunjung homepage tidak mengunduh kode dashboard.

P1

Karantina/hapus `lib/lms.ts` & `lib/commerce.ts`

Pertahankan hanya bagian yang dipakai seeding installer; tandai jelas sebagai "install-time only" agar tidak disangka jalur runtime.

P2

Tambah test otomatis frontend

Minimal cakup kalkulasi keranjang/voucher, scoring kuis di UI, dan alur checkout dengan Vitest.

P2

Bersihkan dependency tak terpakai

Lepas `lucide-react` & `@supabase/supabase-js` dari `package.json` bila memang tidak direncanakan dipakai.
